

Business Continuity Plan for Drata

Preparer: Johanna Kougbeadjo

Date: 7/8/2025

Table of Contents

Introduction 2

1. Concept of Operations 3

2. Activation and Notification 5

3. Recovery..... 6

4. Reconstitution..... 7

5. Plan Testing, Training, and Exercises (TT&E) 9

6. Plan Maintenance 10

References 11

Introduction

This Business Continuity Plan (BCP) outlines Drata’s official strategy for maintaining critical operations during disruptive events. It is not a theoretical guide or recommendation document, but rather the live reference plan that defines how Drata will detect, respond to, and recover from interruptions to its services. The plan covers cybersecurity threats, infrastructure failures, natural disasters, and other significant disruptions.

a. Background

Drata is a U.S.-based company headquartered in San Diego, California, operating as a multi-tenant SaaS platform designed to automate security compliance for standards such as SOC 2, ISO/IEC 27001, HIPAA, PCI DSS, and GDPR. The organization’s core architecture is hosted on Amazon Web Services (AWS), where it leverages Kubernetes for container orchestration, Terraform for infrastructure management, and GitHub Actions for continuous deployment. Drata serves over 3,000 global clients, ranging from fintech to healthcare providers, and maintains integrations with third-party systems such as GitHub, Azure AD, Google Workspace, and various audit frameworks. With a workforce of over 200 employees, Drata’s operations require a continuity strategy that accommodates global service levels, regulatory scrutiny, and cloud-native system dependencies.

As a cybersecurity and compliance automation provider that serves clients across regulated industries, Drata must uphold continuous service availability, integrity, and trust. This document builds on Drata’s Business Impact Analysis (BIA) and Incident Response Plan (IRP), detailing the recovery and reconstitution mechanisms that enable resilience across the organization. The BCP adheres to frameworks such as NIST SP 800-34 Rev. 1, ensuring that continuity efforts are consistent with internationally recognized best practices.

b. Scope

This BCP encompasses the entirety of Drata's operational ecosystem. It applies to all critical systems, business processes, personnel functions, and vendor-supported services that contribute to the platform's availability and compliance functionality. This includes frontend customer interfaces, backend service logic, databases, CI/CD pipelines, authentication mechanisms, and the organizational tools used for communication and project management. The plan also extends to regulatory compliance processes, incident detection workflows, and customer support operations, ensuring that all mission-essential functions are covered during adverse events.

c. Assumptions

This plan is developed with the understanding that certain environmental and operational conditions will remain consistent during its execution. It assumes that AWS infrastructure will provide at least 99.99% uptime through multi-AZ deployments. It also assumes that employees have access to remote work capabilities and that communication platforms like Slack and email will remain operational even when primary systems are affected. Furthermore, the plan presumes that Drata's daily backups, which are encrypted and replicated across AWS regions, are recoverable within tested recovery point objectives. Regulatory requirements such as the 72-hour GDPR breach reporting window are expected to remain unchanged, and detection tools such as AWS GuardDuty and Datadog will continue functioning to provide real-time threat intelligence.

1. Concept of Operations

Drata's business continuity model is rooted in the principle of proactive preparation and coordinated execution. The plan begins with threat detection, followed by stakeholder notification, system recovery, and business reconstitution. Throughout this process, priority is given to the services identified in the BIA as critical to operational continuity. Recovery is executed through a combination of pre-configured infrastructure scripts, infrastructure-as-code deployments, and redundant cloud-native resources. The Incident Response Manager (IRM) leads the continuity effort in collaboration with technical, compliance, and communication teams. The overarching objective is to ensure that disruptions do not compromise Drata's core mission of providing secure and continuous compliance services to its clients.

a. System Description

The Drata platform operates in a zero-trust cloud environment and relies heavily on AWS-managed services for availability and scalability. Its frontend application is built using React and served via AWS CloudFront. The backend consists of Node.js-based microservices deployed on Kubernetes clusters managed through AWS EKS. The system maintains data integrity using PostgreSQL on AWS RDS with multi-AZ failover enabled, as well as Amazon DynamoDB for NoSQL workloads. Persistent customer-uploaded files are stored in encrypted S3 buckets. Infrastructure provisioning and application deployment are fully automated using Terraform and Helm Charts, integrated into GitHub Actions CI/CD pipelines. Access is governed by Okta, with multi-factor authentication and role-based access control policies in place. Drata's environments are logically segregated by function (development, staging, production) and protected through IAM controls and virtual private networks. Security visibility is maintained through GuardDuty and Datadog logging, with all application logs funneled into a central

SIEM system for analysis and alerting. Backups are performed daily and validated quarterly during scheduled disaster recovery drills, which simulate failover to alternate AWS regions using Route 53 and redeployed infrastructure templates (Amazon Web Services, 2023).

b. Overview of Three Phases

Drata's Business Continuity Plan is structured around three operational phases that guide the organization through the lifecycle of incident response: Activation and Notification, Recovery, and Reconstitution. These phases establish a clear and repeatable sequence of actions that ensure rapid detection of disruption, efficient restoration of services, and a controlled return to normal operations. Each phase is interdependent and aligned with the broader objectives of minimizing downtime, preserving data integrity, and maintaining customer trust throughout the disruption lifecycle.

i. Activation and Notification

The activation and notification phase marks the beginning of the BCP execution. In this section, we define how a disruption is identified, how stakeholders are alerted, and which internal protocols initiate the official response. This phase ensures swift mobilization of recovery teams and sets the tone for coordinated communication and mitigation efforts.

ii. Recovery

Once the business continuity plan has been activated, the recovery phase outlines the concrete steps required to bring critical systems and services back online. This section focuses on the orderly restoration of prioritized services based on impact assessments conducted in the BIA, ensuring that essential functions are recovered within their designated recovery time objectives (RTOs).

iii. Reconstitution

After initial recovery is complete, the organization must re-establish full operational capability across all systems and business functions. The reconstitution phase ensures that data is validated, functionality is thoroughly tested, and stakeholders are officially notified that operations have resumed. This section describes how Drata transitions from a recovery state back to normal business operations while maintaining system integrity and auditability.

c. Roles and Responsibilities

The execution of this BCP depends on well-defined roles distributed across multiple teams. The Chief Information Security Officer (CISO) maintains strategic oversight and ensures executive alignment. The Incident Response Manager (IRM) coordinates the activation, leads the incident bridge calls, assigns recovery tasks, and maintains incident logs. Engineering leads are responsible for the technical recovery of systems and services, including redeployments and rollback validation. GRC officers manage regulatory timelines, client-facing attestations, and audit log retention. The Security Operations Center (SOC) monitors alerts and assists in validating the reconstitution process through forensic tooling and log review. Customer support leads manage all external communication regarding service status. The Human Resources department ensures employee availability, addresses physical access issues, and provides continuity

in staffing during long-term outages. Each role includes primary and secondary delegates with documented escalation paths and on-call schedules maintained quarterly.

2. Activation and Notification

This section describes how Drata formally activates its BCP during a disruptive incident, including detection, escalation, internal and external communication, and impact assessment. It expands upon the earlier conceptual overview and provides detailed procedural steps to ensure swift mobilization of response teams and effective stakeholder coordination during incidents.

a. Activation Criteria and Procedure

The activation of the BCP is triggered by specific criteria designed to identify significant disruptions to Drata's operations (Calder, 2020). These criteria include prolonged system outages exceeding 30 minutes, confirmed security breaches such as data exfiltration or ransomware attacks, and natural disasters affecting primary data centers or critical infrastructure. Additionally, the BCP may be activated in response to regulatory mandates or significant third-party service disruptions that impact Drata's ability to deliver services.

The activation procedure begins with the identification of an incident by the SOC or through automated monitoring tools such as AWS GuardDuty and Datadog. Once an incident is detected, the SOC conducts an initial assessment to determine its severity and potential impact. If the incident meets the activation criteria, the SOC escalates the issue to the IRM, who makes the final decision to activate the BCP.

Upon activation, the IRM initiates the notification process, alerting key stakeholders and assembling the Incident Response Team. Internal teams are notified through automated Slack messages and PagerDuty incident bridges, ensuring rapid mobilization of resources. The IRM also activates pre-defined communication templates stored in Confluence, customizing them as needed to notify customers and third-party partners. External notices are issued via email and updated on Drata's public status page within 30 minutes of confirmed disruption.

b. Notification

Once the BCP is activated, timely and structured communication is essential. The Incident Response Manager is responsible for initiating all notifications. Internal teams are alerted through automated Slack messages and PagerDuty incident bridges. Communication templates for notifying customers and third-party partners are stored in Confluence and customized by the GRC and Communications leads depending on the severity and scope of the event. External notices are issued via email and updated on Drata's public status page within 30 minutes of confirmed disruption. Media inquiries, if any, are redirected to a designated Communications Officer (Calder, 2020).

c. Outage Assessment

Upon activation, Drata conducts an initial outage assessment to determine the scope, severity, and impact of the disruption. The SOC, in collaboration with Engineering and GRC teams, collects telemetry from AWS GuardDuty, Datadog, and internal monitoring dashboards. The assessment categorizes the event using Drata's Severity Assessment Matrix, which classifies outages from Level 1 (minor user impact) to Level 4 (complete

service disruption or legal/regulatory risk). The outcome of this assessment guides resource allocation, stakeholder engagement, and regulatory reporting obligations.

3. Recovery

Once the BCP has been activated, the recovery phase guides the structured restoration of Drata's prioritized systems. Each action follows a sequence based on criticality, ensuring that services resume within their defined recovery time objectives (RTOs). This section details recovery sequencing, execution procedures, and escalation protocols to ensure a coordinated and auditable recovery process.

a. Sequence of Recovery Activities

System recovery is driven by predefined priorities established in the BIA. The customer compliance portal, as the most critical interface, is restored first via redeployment through the CI/CD pipeline. Validation scripts and synthetic transactions ensure that portal functionality matches expected performance metrics before re-exposing it to users. Backend services are recovered next using Helm rollback procedures to restore prior stable releases. The PostgreSQL databases are restored via point-in-time recovery snapshots, orchestrated by Terraform, while S3 data is accessed from replicated buckets. During recovery, logs are closely monitored for anomalies, and compliance obligations are addressed through coordination with the GRC team. Throughout the recovery window, Grafana dashboards and Confluence-based runbooks guide execution, ensuring transparent progress tracking.

b. Recovery Procedures

The recovery procedures section outlines the specific steps required to restore Drata's mission-critical systems following the activation of the BCP. These procedures are designed to ensure a structured and prioritized approach to recovery, minimizing downtime and ensuring that essential functions are restored within their designated RTOs.

The first step in the recovery process involves the redeployment of the customer compliance portal, which is the most critical interface for Drata's clients. This is achieved through the CI/CD pipeline, using pre-configured deployment scripts to ensure a rapid and consistent restoration. Validation scripts and synthetic transactions are employed to confirm that the portal's functionality matches expected performance metrics before it is re-exposed to users.

Following the restoration of the customer compliance portal, attention shifts to the recovery of backend services. This is accomplished using Helm rollback procedures to restore prior stable releases of the microservices. The PostgreSQL databases are restored via point-in-time recovery snapshots, orchestrated by Terraform, while S3 data is accessed from replicated buckets (Amazon Web Services, 2023). Throughout the recovery process, logs are closely monitored for anomalies, and compliance obligations are addressed through coordination with the GRC team.

During the recovery phase, the IRM ensures that all recovery activities are documented and tracked using Grafana dashboards and Confluence-based runbooks. This provides

transparency and accountability, enabling stakeholders to monitor progress and make informed decisions. The IRM also coordinates with the SOC to ensure that any security-related issues are addressed promptly and effectively.

c. Recovery Escalation Notices/Awareness

Effective communication is crucial during the recovery phase to ensure that all stakeholders are kept informed of progress and any potential issues. The IRM is responsible for issuing recovery escalation notices and maintaining awareness throughout the organization.

Internal teams are provided with regular updates through automated Slack messages and PagerDuty incident bridges. These updates include information on the status of recovery efforts, any challenges encountered, and the expected timeline for resolution. The IRM also conducts periodic briefings with key stakeholders, including the Executive Team, to provide a high-level overview of the recovery process and address any concerns.

External stakeholders, including customers and third-party partners, are kept informed through regular updates on Drata's public status page and via email. These updates are customized by the GRC and Communications leads to ensure that they are accurate, timely, and relevant. The Communications Officer handles media inquiries and ensures that all external messaging is consistent and aligned with Drata's brand and values.

In the event of significant delays or issues during the recovery process, the IRM is responsible for escalating the matter to the CISO and, if necessary, to the Board of Directors. This ensures that appropriate resources and support are mobilized to address the issue and minimize the impact on Drata's operations and reputation.

4. Reconstitution

The reconstitution phase represents Drata's transition from recovery to full operational capacity. This stage ensures data validation, functionality testing, final documentation, and the formal closure of recovery operations. The subsections below define how Drata verifies system integrity, cleans up temporary components, and officially resumes business-as-usual operations with lessons learned in hand.

a. Validation Data Testing

Following the recovery of core systems, a structured data validation process is initiated to ensure the integrity and completeness of restored information. Engineering teams use hash-based verification, automated checksums, and log comparison scripts to confirm that data within RDS and DynamoDB reflects a consistent state prior to the incident. Backup restoration logs are reviewed, and any discrepancies are reconciled using audit trails and replication timestamps. If inconsistencies are detected, data is re-synced from the most recent valid backup and subjected to forensic examination.

b. Validation Functionality Testing

Once data validation has been completed, functional testing is conducted to confirm that

system features are operating as intended. This includes user authentication, evidence collection workflows, compliance status dashboards, API integrations, and frontend responsiveness. QA engineers deploy automated end-to-end regression tests and manual verification scripts using staging datasets. Business users from the GRC and Support teams perform scenario-based usability testing to ensure the environment matches pre-incident performance and security baselines.

c. Recovery Declaration

When validation steps confirm both data accuracy and platform functionality, the Incident Response Manager consults with leads from Engineering, GRC, and Customer Success to finalize the recovery status. A formal recovery declaration is issued via Confluence and Slack, signaling the closure of the recovery phase. This declaration triggers notifications to internal stakeholders and external customers, affirming that services are fully operational and normal business workflows may resume.

d. Cleanup

Post-recovery cleanup includes decommissioning any temporary infrastructure components, such as emergency virtual machines or diagnostic tools, and revoking elevated IAM roles used during response. Temporary access logs, firewall exceptions, and DNS overrides are cleared or documented for audit. Redundant backups generated during the restoration phase are encrypted and securely purged if no longer required. All changes made during the incident are reviewed for permanence or reversal, and documentation is finalized in the associated Jira ticket.

e. Offsite Data Storage

Drata employs AWS S3 with cross-region replication as its primary offsite data storage strategy. Backup buckets are configured with Object Lock and versioning, ensuring that historical data snapshots remain immutable for their defined retention periods. These offsite backups are stored in physically separate regions and are validated quarterly through controlled test restores. Retention policies align with regulatory requirements, ensuring both resilience and compliance.

f. Data Backup

Data backup processes occur automatically on a daily basis. RDS instances are configured with point-in-time recovery (PITR) and retain backups for a 14-day rolling window. Snapshots are encrypted using AWS KMS and tagged for visibility. DynamoDB tables and S3 buckets undergo scheduled backups through AWS Backup, and audit evidence files are replicated across AWS regions. All backup operations are logged and monitored through Datadog and CloudWatch, and quarterly recovery tests ensure backup reliability and accessibility during incident scenarios.

g. Event Documentation

A detailed post-event report is created for each BCP activation. This report includes a timeline of events, recovery milestones, impact assessments, lessons learned, and recommended corrective actions. Logs, screenshots, and recovery outputs are archived in

Confluence, with cross-links to Jira incident tickets and audit checklists. Documentation follows NIST SP 800-61r2 guidance and is peer-reviewed by Engineering, GRC, and the Risk Governance Committee. The finalized report is retained for audit purposes and referenced in future tabletop exercises.

h. Deactivation

The deactivation phase marks the formal conclusion of BCP procedures. It includes the transition of responsibility from the IRM back to normal business owners. Systems are monitored for an additional period of heightened oversight, typically 24-72 hours, to detect any latent issues. Any open action items or CAPAs (Corrective and Preventive Actions) are logged in the risk management register. Once all objectives are verified as complete, the incident is marked as resolved, and the BCP lifecycle for that event is officially closed.

Reconstitution begins once all priority services have been restored and validated. At this stage, system functionality is re-tested under normal load conditions. Post-incident forensics are conducted to confirm the absence of malicious artifacts or incomplete rollback states. Engineering teams validate service interactions and perform codebase integrity checks. The Incident Response Manager coordinates a return-to-operations declaration, once confirmation is received from all functional owners. Any temporary configurations, access rules, or monitoring bypasses enacted during recovery are reversed. Final actions include documentation of the incident timeline in Confluence, archiving of logs and communications, and a post-mortem review to identify gaps. Rotating credentials, verifying user provisioning logs, and ensuring that all downstream audit reports are consistent with post-recovery states are integral to completing this phase.

5. Plan Testing, Training, and Exercises (TT&E)

The TT&E program ensures that Drata's Business Continuity Plan remains actionable and effective through structured evaluation, staff preparation, and simulated response activities. This comprehensive program includes quarterly tabletop exercises, semi-annual functional drills, annual full-scale simulations, and year-round targeted training initiatives to assess and reinforce readiness across the organization.

Quarterly tabletop exercises involve key stakeholders from Engineering, GRC, Security Operations, Customer Support, and Executive Leadership. These sessions walk through specific disruption scenarios such as ransomware incidents, regional AWS outages, or compliance audit failures. Stakeholders analyze the decisions that would be made during each phase of the BCP and evaluate the clarity and feasibility of escalation and communication procedures. Output from these sessions is documented in Confluence and used to improve future playbooks and communication templates.

Semi-annual functional drills are conducted with hands-on engagement from technical teams. These drills test specific components of the recovery process such as restoring encrypted snapshots from S3 using Terraform, failing over RDS clusters using AWS Console and CLI, or executing DNS rerouting with Route 53. Drills include synthetic data validation, metrics monitoring through Grafana, and recovery verification steps managed in Jira tickets.

Annual full-scale simulations require company-wide mobilization and full BCP activation. These events simulate scenarios such as a data center region-wide failure or coordinated credential compromise. During these simulations, the Incident Response Manager leads bridge calls, stakeholders issue internal and customer-facing status updates using Confluence templates, and all teams execute the full sequence from activation through reconstitution. After-action reports are compiled within five business days and presented to the Risk Governance Committee.

The training component of the TT&E program complements these exercises. All new employees are introduced to the BCP during onboarding and are required to complete a BCP fundamentals course via the company LMS within their first 30 days. Training materials cover the scope of the plan, escalation contacts, incident categorization, and specific departmental roles. Role-specific training is conducted quarterly for critical positions such as the IRM, SOC analysts, and GRC officers. These sessions are instructor-led and cover the practical execution of BCP tasks including severity matrix application, forensic log review procedures, and compliance notification workflows.

Throughout the year, refresher modules are provided through Drata's internal LMS platform and include short scenario-based quizzes and documentation walkthroughs. This ensures that all personnel remain aware of evolving recovery steps, changes in regulatory timelines, and updates to technical procedures.

The TT&E program as a whole supports a culture of resilience by promoting awareness, accountability, and continuous improvement. Feedback from tabletop exercises, drills, and simulations is analyzed by the GRC team and used to update the BCP biannually or after any material incident. Updates are tracked in version-controlled Confluence documentation, and summaries are shared company-wide during quarterly security briefings. These structured improvements help Drata remain agile in the face of potential cyberincident (Amoo et al., 2024).

6. Plan Maintenance

To remain effective and responsive to changing threats, technologies, and business operations, Drata's BCP must be a living document (Snedaker & Rima, 2014). The maintenance process ensures that updates are made regularly and systematically.

To ensure its relevance and applicability, Drata's BCP is maintained on a structured review schedule. At minimum, the plan is reviewed every six months or following any material incident. Changes to the organizational structure, cloud architecture, compliance frameworks, or third-party dependencies trigger an out-of-cycle review. The GRC team owns the version control process in Confluence, where updates are proposed, reviewed by stakeholders, and approved by the CISO. Once finalized, changes are communicated via company-wide announcements and documented in the internal policy repository. Lessons learned from previous incidents, audit findings, and regulatory updates also inform continuous improvement of the plan. A change log is maintained for auditability, and every version of the BCP includes a metadata header detailing the last modified date, approver, and summary of revisions.

References

- Amoo, O., Abrahams, T., Farayola, O., Amoo, O., Ayinla, B., Osasona, F., & Atadoga, A. (2024). Continuous improvement in information security: A review of lessons from superannuation cybersecurity uplift programs. *International Journal of Science and Research Archive*, 11, 1327–1337.
<https://www.researchgate.net/publication/378105766>
- Amazon Web Services. (2023). *Disaster Recovery of Workloads on AWS: Recovery in the Cloud*.
<https://docs.aws.amazon.com/whitepapers/latest/disaster-recovery-workloads/introduction.html>
- Calder, A. (2020). *The cyber security handbook – Prepare for, respond to and recover from cyber attacks*. IT Governance Publishing.
- Snedaker, S., & Rima, C. (2014). *Business continuity and disaster recovery planning for IT professionals* (2nd ed.). Syngress.